

Hafta 7 – Ara Proje Gösterimleri

Tarih	30.10.2026
Öğrenme çıktıları	ÖÇ.1, 2, 3, 5, 7
Süre	3 saat



Bu hafta ne oluyor?

Bu hafta ders anlatılmaz. Dönem projesinin **ilk kontrolü (RAP1)** yapılır: her takım ara raporunu (güvenlik kılavuzunun vize bölümleri) teslim eder ve çalışan uygulamasını gösterir. RAP1, vize notunun **%60'ıdır**; kalan %40 gelecek haftaki Quiz-1'dir ($Not_Vize = 0,6 \cdot RAP1 + 0,4 \cdot QUIZ1$). Ayrıntılı rubrik (kriterler, puanlar, başarı düzeyleri) dersin proje rehberindedir; bu sayfa, gösterime hazırlanmanız için bir kontrol listesidir.



Teslim ve süre kuralları

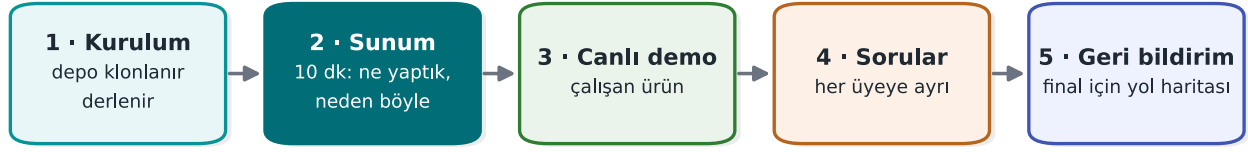
Geç teslim kabul edilmez (izlence, bölüm G). Gösterim sırası, takım başına süre ve teslim saati ders sınıfında duyurulur. Beklenmedik bir durum yaşarsanız öğretim üyesine **gösterimden önce** haber verin.

1. Vize kontrolü neyi ölçer?

İzlencedeki vize kontrolü rubriğinin beş kriteri ve güvenlik kılavuzunuzda karşılık gelen bölümler:

Gösterim günü akışı

toplam 20 dakika · takımın HER üyesi konuşur



Yazdığınız her satırı açıklayabilmelisiniz; açıklayamadığınız kod puan getirmez.

Kriter	Öğrenme çıktısı	Kılavuzda nerede?	Hangi haftalar?
Güvenlik analizi	ÖÇ.1	S2 ürün genel bakışı · S3 mimari ve arayüz tablosu · S4 tehdit ve saldırı modeli	1, 2
Veri güvenliği	ÖÇ.2	S5 varlık listesi (taslak) · S7 veri güvenliği ve güvenlik kabuğu matrisi	1, 3
C/C++ kod sağlamlaştırma ve RASP	ÖÇ.3	S9 kod sağlamlaştırma (temel) · S10 RASP ve tepki politikası	4, 6
Proje yönetimi	ÖÇ.5	S13 geliştirme ortamı ve süreci, SBOM, değişiklik yönetimi · GitHub deposu ve plan	1, 5
Ara rapor	ÖÇ.7	Vize sütunundaki bütün bölümler, belge düzeni, kaynaklar	Tümü

Ara raporda bulunması gereken bölümler

Güvenlik kılavuzunuzun bölüm yapısı dönem boyunca aynıdır; vize kontrolünde bir kısmı tam, bir kısmı taslak olarak beklenir:

No	Bölüm	Vize kontrolünde
S0	Kapak, belge kontrolü, sürüm geçmişi	Tam
S1	Kapsam, hedef kitle, kısaltmalar, kaynaklar	Taslak
S2	Ürün genel bakışı	Tam
S3	Mimari ve arayüz tablosu, güven sınırları	Tam
S4	Tehdit modeli ve saldırgan modeli (STRIDE, saldırı tablosu, CWE)	Tam
S5	Varlık listesi ve varlık koruma şeması (C/I/I+)	Taslak
S7	Veri güvenliği (beklemede/kullanımda/aktarımda) + güvenlik kabuğu matrisi	Tam
S9	Kod sağlamlaştırma (derleyici sertleştirilmesi, gizleme)	Temel
S10	RASP + tepki politikası	Tam
S12	Raporlama ve günlükleme politikası	Kısa
S13	Geliştirme ortamı ve süreci, SBOM, değişiklik yönetimi	Tam
S16	Güvenlik testi ve doğrulama	Plan
S17	Gereksinim uyum matrisi	Taslak

S6, S8, S11, S14 ve S15 final kontrolüne kalır.

2. Hafta hafta hazırlık kontrol listesi

Aşağıdaki liste, ilk altı haftanın "Dönem projesi: bu hafta" bölümlerindeki görevleri tek yerde toplar. Her maddeyi kılavuzunuzda ve deponuzda gösterebiliyor olmalısınız.

RAP1 (vize) teslimi: ne bekleniyor?

ürünün ilk yarısı + kılavuzun ilk bölümleri

S2 · Ürün ve mimari	bileşenler, arayüzler, güven sınırları
S3 · Arayüzler	her arayüz için doğrulama
S4 · Tehdit modeli	STRIDE + saldırı ağacı
S5 · Varlık listesi	her varlık: konum, koruma şeması
Temel korumalar	AEAD, güvenli silme, girdi doğrulama

$RAP1 = 0,7 \cdot \text{vize notu}$. Kalan 0,3 Quiz-1'den gelir.

✓ 1. hafta – Proje planı ve ilk bölümler

- ✓ GitHub deposu, README, proje planı (iş paketleri, takvim, görev dağılımı) onaylatıldı.
- ✓ S0 kapak ve sürüm geçmişi.
- ✓ S2 ürün genel bakışı: uygulama ne yapıyor, kim kullanıyor?
- ✓ S3 mimari şema ve **arayüz tablosu** (her arayüz için uçlar, kimlik doğrulama, gizlilik/bütünlük).
- ✓ S4 saldırgan modeli, STRIDE tablosu, en az bir **saldırı ağacı**.
- ✓ S5 varlık listesi taslağı: konum, oluşma → silinme, C/I/I+.

✓ 2. hafta – Tehdit tablosu ve sınıflandırma

- ✓ S4 tehdit tablosunda her tehdit bir **CWE** ile eşleşiyor ve **CVSS v3.1** vektörü var.
- ✓ Saldırı ağacı bir aracın girdi biçiminde ya da çizim olarak ekli.
- ✓ Tehditler arayüz tablosundaki satırlardan çıkarıldı; her varlık en az bir tehditte geçiyor.

✓ 3. hafta – Veri güvenliği

- ✓ S7 aktarımda, beklemede ve kullanımda veri için hangi algoritma, hangi anahtar, hangi bağlama?
- ✓ En hassas varlık için **güvenlik kabuğu matrisi** (aşama × kabuk).
- ✓ Rastgele değerler CSPRNG'den; AEAD etiketi açık metin kullanılmadan önce doğrulanıyor.
- ✓ TLS kullanılıyorsa doğrulama + ana makine adı denetimi (+ varsa sabitleme) gösterilebiliyor.

✓ 4. hafta – C/C++ sağlamlaştırma

- ✓ S9: derleyici koruma tablosu (`checksec` / `dumpbin`); kapalı kalan koruma varsa gerekçesi.
- ✓ CERT kurallarına göre tarama; en az beş bulgu düzeltildi ve kural kimliğiyle belgelendi.
- ✓ Testler ASan + UBSan ile çalıştı; en az bir fuzz hedefi ve sonucu.
- ✓ Sürümde günlük yok, hassas dizge `strings` çıktısında yok.

✓ 5. hafta – Bağımlılıklar ve girdi doğrulama

- ✓ S13: CycloneDX biçiminde SBOM ve zafiyet taraması sonucu.
- ✓ Girdi doğrulama tablosu: her giriş noktası için biçim, uzunluk sınırı, doğrulayan fonksiyon.

✓ 6. hafta – RASP

- ✓ S10: her kritik işlem için hangi RASP denetimleri, ne zaman, nerede çalışıyor?
- ✓ Tepki politikası: hangi sır silinir, fail-closed mı, decoy mu, olay nereye bildirilir?
- ✓ En az bir denetimin atlatma denemesi ve sonucu (S16 planına da yazılır).

3. Gösterim: önerilen akış

Gösterim, bir değerlendiricinin ürününüzü ilk kez incelediği toplantı gibi düşünülmelidir. Süre sınırlıdır; önceden prova edin. Önerilen sıra:

Gösterimde sık yapılan hatalar

değerlendirici kanıt arar, iddia değil

YAPMAYIN

slaytta kod okumak
'çalışıyor' deyip göstermemek
tek kişinin konuşması
kanıtsız 'güvenli' iddiası

YAPIN

çalışan demoyu göstermek
kararın GEREKÇESİNİ anlatmak
ölçüm/kanıt sunmak
sınırları dürüstçe söylemek

'Şunu yapamadık, nedeni şu' demek, olmayan bir şeyi var göstermekten iyidir.

1. **Ürün ve mimari (S2–S3):** Uygulama ne yapıyor? Arayüz tablosunu ve güven sınırlarını tek bir şemada gösterin.
2. **Tehditler ve varlıklar (S4–S5):** En kritik üç tehdit ve bunların hedeflediği varlıklar.

3. **Canlı gösterim:** Uygulamayı çalıştırın; en az bir güvenlik önlemini **çalışırken** gösterin (ör. kurcalanmış bir dosyanın reddedilmesi, bir RASP denetiminin tetiklenmesi).
4. **Kanıt:** Koruma tablosu, sanitizer/fuzzing sonucu, SBOM; "yaptık" değil "şu komutla şu çıktıyı aldık".
5. **Kalan risk ve plan:** Neyi henüz yapmadınız, finale kadar ne yapacaksınız?



Değerlendirici gibi düşünün

Her önlem için üç soruya cevap hazırlayın: **Neyi korur?** (hangi varlık, hangi tehdit) · **Nasıl yapıldı?** (dosya, fonksiyon, bayrak) · **Nasıl kanıtlandı?** (test, komut, çıktı). Cevabı "testini yapmadık" olan önlem, gözünde henüz yoktur.

Gösterimde sorulabilecek örnek sorular

- Arayüz tablonuzda güven sınırını geçen hangi akış en riskli? Neden?
- Bu varlık bellekte ne kadar süre açık kalıyor? Nerede siliniyor? Derleyicinin silmeyi kaldırmadığını nasıl doğruladınız?
- Şifreleme anahtarınız nereden geliyor, nerede duruyor? Nonce tekrar edebilir mi?
- Hangi derleyici koruması kapalı? Neden?
- RASP denetiminiz başarısız olunca ne oluyor? Tepki, tetikleyicinin hemen yanında mı?
- SBOM'unuzda bilinen zafiyetli bir bileşen var mı? Etkileniyor musunuz?
- Tehdit tablonuzdaki T3 için önlem hangi bölümde anlatılıyor ve nasıl test edildi?

Sık yapılan hatalar

Hata	Neden sorun?
Kılavuzda anlatılan önlem kodda yok (ya da tersi)	Belge ile ürün tutarsız: değerlendirici gözünde en ciddi bulgulardan biri
"Güvenli" demek, kanıt göstermemek	Kanıtsız iddia puanlanmaz
Varlık listesinde anahtarlar, günlükler ve kodun kendisi yok	Listede olmayan varlık korunmuyor demektir
Tehdit tablosu arayüzlerden değil, genel bilgiden yazılmış	Projeye özgü tehditler kaçırılır
Canlı gösterimin prova edilmemesi	Süre boşa gider; çalışmayan gösterim puanı düşürür
Depoda gizli bilgi (parola, anahtar, kişisel veri)	Ciddi bir güvenlik hatası; bütün değerler sentetik olmalı

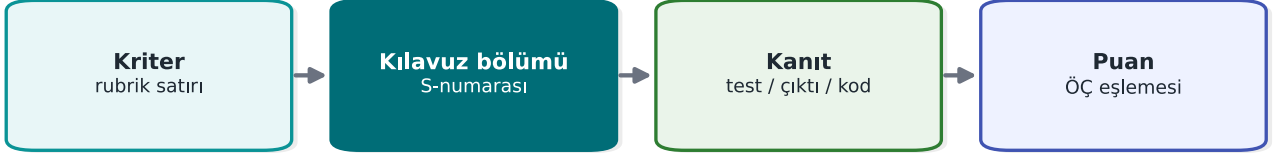
4. Akademik dürüstlük

İzlencenin "Akademik Dürüstlük" bölümü projede de geçerlidir: başkasının kodunu ya da metnini kaynak göstermeden kullanmak, takım dışından çalışma almak ve sonuçları uydurmak kabul edilmez. Teslim ettiğiniz her satırı açıklayabiliyor

olmalısınız. Gösterimde takımın her üyesine soru sorulabilir.

Rubrik nasıl okunur?

her puan satırı bir kanıta bağlanır



Kanıtı olmayan satır puanlanmaz — 13. haftanın uyum matrisi mantığı burada da geçerli.

5. Gösterimden sonra

- Aldığınız geri bildirimleri bir **bulgu listesi** olarak yazın (bulgu, önem, düzeltme planı, hedef tarih). Bu liste,
- haftada göreceğimiz değerlendirme sürecinin küçük bir modelidir.
- Final kontrolünde beklenen bölümler (S6 kimlik doğrulama ve bağlama, S8 kriptoloji ve anahtar yaşam döngüsü, S11 güvenli iletişim, S14 varsayımlar ve devredilen gereksinimler, S15 derleme ve dağıtım hattı, S16 test sonuçları, S17 uyum matrisi) 9–14. haftaların konularıyla doldurulacak.